

Caso de estudio #2

"Redacción de políticas y procedimientos de seguridad de la información Florbella."

Oscar Chavarría Hernández

Universidad CENFOTEC

Gestión de Riesgos

Profesor: JORGE ROBERTO MORA SEGURA

2025

Introducción

En la actualidad, la protección de la información es fundamental para la continuidad y éxito de cualquier empresa, especialmente para aquellas que manejan operaciones tanto físicas como digitales. Florabella S.A., una empresa dedicada a la venta de flores a través de una tienda física y una plataforma en línea, enfrenta desafíos significativos para asegurar la confidencialidad, integridad y disponibilidad de su información, incluyendo datos personales y financieros de sus clientes.

Este informe presenta las políticas y procedimientos diseñados para fortalecer la seguridad de la información y regular el trabajo remoto en Florabella S.A., garantizando el cumplimiento de normativas internacionales como ISO/IEC 27001 y el Reglamento General de Protección de Datos (GDPR), así como la legislación local. Además, se incluye un análisis de riesgos, un estudio de impacto al negocio y simulaciones de escenarios para orientar la implementación de controles efectivos y proteger los activos críticos de la empresa.

Política 1: Política de Seguridad de la Información

Propósito:

Proteger la confidencialidad, integridad y disponibilidad de la información manejada por Florabella S.A., garantizando el cumplimiento de normativas internacionales como ISO/IEC 27001 y el Reglamento General de Protección de Datos (GDPR).

Alcance:

Esta política aplica a todos los empleados, contratistas y terceros que tengan acceso a la información de Florabella S.A., incluyendo los sistemas de gestión de pedidos, plataforma de comercio electrónico, software de punto de venta (POS), almacenamiento en la nube y herramientas de marketing digital.

Definiciones:

Información confidencial: Datos internos de la empresa cuya divulgación no autorizada puede causar perjuicios.

Datos personales: Información que permite identificar a una persona, como nombre, dirección, correo electrónico y número de teléfono.

Datos de pago: Información financiera de los clientes, como números de tarjetas de crédito o débito.

Políticas específicas:

1. Toda información confidencial debe almacenarse en medios cifrados, ya sea localmente o en la nube.

2. Se deberá restringir el acceso a la información según el principio de mínimo privilegio.
3. Los usuarios deben autenticarse mediante credenciales seguras y autenticación multifactor (MFA) donde sea posible.
4. Todo acceso a los sistemas será monitoreado y registrado.
5. Se deben realizar copias de seguridad automáticas y periódicas.
6. El uso de dispositivos personales para tareas laborales debe ser aprobado y configurado con medidas de seguridad.
7. Se debe realizar una capacitación anual obligatoria en seguridad de la información.

Roles y responsabilidades:

Empleados: Cumplir con las políticas de seguridad, reportar incidentes y participar en capacitaciones.

Administradores del sistema: Configurar y mantener controles de acceso, supervisar registros de auditoría y asegurar el cifrado de la información.

Equipo de TI: Implementar soluciones técnicas de seguridad, ejecutar auditorías internas y mantener los sistemas actualizados.

Cumplimiento:

Se realizarán auditorías internas cada seis meses para evaluar el cumplimiento.

Se revisarán los accesos y permisos de usuarios cada trimestre.

Se aplicarán cuestionarios de verificación a los empleados tras las capacitaciones anuales.

Consecuencias:

Los incumplimientos serán analizados por el Comité de Seguridad.

Las sanciones pueden incluir advertencias, suspensión temporal del acceso a sistemas, medidas disciplinarias o terminación del contrato laboral.

Referencias:

ISO/IEC 27001:2022

Reglamento General de Protección de Datos (GDPR)

Ley 8968 – Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales (Costa Rica)

Matriz de Riesgo a la Seguridad de la Información:

Riesgo identificado	Probabilidad	Impacto	Nivel de Riesgo	Controles Propuestos
Acceso no autorizado a datos personales	Media	Alto	Alto	MFA, registros de auditoría, principio de mínimo privilegio
Pérdida de respaldos	Baja	Muy Alto	Alto	Backups automáticos y pruebas de restauración
Uso no autorizado de dispositivos personales	Alta	Alto	Crítico	Políticas de BYOD, cifrado obligatorio, antivirus actualizado
Brecha en POS o ecommerce	Media	Alto	Alto	Parches rápidos, monitoreo constante, segmentación de red
Robo de información desde la nube	Baja	Alto	Medio	Cifrado extremo a extremo, monitoreo, control de acceso

BIA (Análisis de Impacto al Negocio):

Se identifican los siguientes procesos críticos:

Proceso	Dependencias tecnológicas	MTD (tiempo máximo de interrupción)	Impacto si se interrumpe
Procesamiento de pagos	POS, base de datos, conexión VPN	2 horas	Pérdida de ingresos directa
Gestión de pedidos	ERP, portal de ecommerce	4 horas	Cancelaciones y reputación
Comunicación con clientes	CRM, correo, servidores cloud	6 horas	Quejas y deterioro de imagen
Copias de seguridad	Servidores cloud cifrados	12 horas	Pérdida de datos críticos

Simulación de Monte Carlo:

Escenario: Probabilidad de ocurrencia y pérdida financiera por incidente de ransomware.

- Iteraciones simuladas: 10,000
- Variables: Tiempo de inactividad (1-72h), nivel de impacto financiero (US\$500 - US\$50,000 por hora), frecuencia esperada (1 evento cada 2 años)
- Resultado estimado:
 - Pérdida media anual esperada (ALE): US\$68,400
 - Desviación estándar: US\$21,700
 - Peor caso en el percentil 95: US\$142,000

Estos resultados orientan la inversión prioritaria en medidas de prevención (copia inmutable, EDR, simulacros de respuesta).

Política 2: Política de Trabajo Remoto

Propósito: Establecer directrices claras para proteger la información de la empresa y mantener la productividad de los empleados que realizan sus funciones desde ubicaciones remotas.

Alcance: Aplica a todos los empleados de Florabella S.A. que realicen trabajo remoto de forma ocasional o regular, independientemente de su rol o departamento.

Definiciones: Trabajo remoto: Modalidad laboral que permite desempeñar funciones fuera de las instalaciones de la empresa, mediante el uso de tecnologías digitales. Dispositivo seguro: Equipos que cumplen con las medidas mínimas de seguridad (antivirus, firewall, cifrado de disco). Acceso remoto: Conexión segura a los sistemas y recursos de la empresa a través de redes externas.

Políticas específicas:

1. Todo trabajo remoto debe realizarse a través de una red privada virtual (VPN) corporativa.
2. Los dispositivos utilizados para el trabajo remoto deben estar protegidos con software antivirus actualizado y contraseñas seguras.
3. Se prohíbe el uso de redes Wi-Fi públicas sin las debidas medidas de cifrado.

4. La información sensible no debe almacenarse localmente en dispositivos personales sin autorización previa.
5. Se deben cerrar las sesiones y bloquear los dispositivos al dejar de usarlos.
6. Los empleados deben notificar al equipo de TI ante cualquier pérdida o robo de dispositivos.

Roles y responsabilidades: Empleados remotos: Seguir los lineamientos establecidos, proteger los dispositivos y mantener la confidencialidad de la información. Equipo de TI: Proveer herramientas de acceso remoto seguro, realizar mantenimientos y configurar equipos de acuerdo con las políticas. Supervisores: Verificar que los empleados cumplan con los lineamientos y reportar incidentes o incumplimientos.

Cumplimiento: Se realizará monitoreo del uso de herramientas seguras mediante software de gestión remota. Se aplicarán auditorías de cumplimiento cada seis meses a los entornos de trabajo remoto. Encuestas de autoevaluación serán enviadas a los empleados remotos de forma semestral.

Consecuencias: Advertencias formales por incumplimientos leves. Revocación del permiso de trabajo remoto ante faltas graves. Medidas disciplinarias según el reglamento interno de trabajo.

Referencias: ISO/IEC 27001:2022 Guías del NIST para el trabajo remoto seguro Guía de Buenas Prácticas para Teletrabajo del Ministerio de Trabajo y Seguridad Social de Costa Rica

Matriz de Riesgo Trabajo Remoto:

Riesgo identificado	Probabilidad	Impacto	Nivel de Riesgo	Controles Propuestos
Uso de Wi-Fi pública insegura	Alta	Medio	Alto	Uso obligatorio de VPN, bloqueo de acceso a redes públicas
Robo de laptop sin cifrado	Media	Alto	Alto	Cifrado de disco, bloqueo remoto, política de notificación inmediata
Malware en dispositivos personales	Alta	Alto	Crítico	Antivirus actualizado, restricción de software, capacitación

Acceso no autorizado por terceros	Media	Medio	Medio	Políticas de no compartir dispositivos, MFA
Pérdida de información en equipos remotos	Baja	Alto	Medio	Backups remotos, almacenamiento cifrado

BIA (Análisis de Impacto al Negocio):

Proceso	Recursos clave (remotos)	MTD	Impacto estimado
Soporte al cliente	Aplicaciones de comunicación	6 horas	Reducción en satisfacción del cliente
Venta online	Sistema de ecommerce, VPN	4 horas	Pérdida directa de ingresos
Control de inventario	Acceso remoto a ERP	8 horas	Errores logísticos, retrasos

Monte Carlo al Trabajo Remoto:

Escenario: Incidentes simultáneos de seguridad remota (ransomware, fallos de acceso, pérdidas de equipos)

- Iteraciones: 1,000
- Variables: Fallo en VPN, ataque por malware, tiempo de recuperación, número de empleados remotos afectados
- Resultados:
 - Pérdida media anual: US\$41,200
 - Riesgo máximo proyectado: US\$115,000
 - Justificación de inversión: Fortalecer sistemas de gestión de endpoints, VPN redundante y entrenamiento periódico

Procedimiento: Seguridad de la Información

Propósito:

Implementar acciones operativas específicas para proteger la información crítica de Florabella S.A., garantizando su confidencialidad, integridad y disponibilidad.

Alcance:

Este procedimiento aplica a todos los sistemas de información utilizados en la empresa, tanto en la tienda física como en la plataforma en línea.

Responsables:

Equipo de TI

Administradores del sistema

Empleados de todas las áreas

Definiciones:

Backup: Copia de seguridad de datos para recuperación ante incidentes.

Cifrado: Técnica para proteger datos haciéndolos ilegibles sin clave de acceso.

Instrucciones paso a paso:

1. Realizar copias de seguridad automáticas cada 24 horas en servidores en la nube cifrados.
2. Verificar semanalmente que los backups sean recuperables mediante pruebas de restauración.
3. Configurar y revisar trimestralmente los permisos de acceso de los usuarios en todos los sistemas.
4. Aplicar parches y actualizaciones de software dentro de las 48 horas posteriores a su liberación.
5. Ejecutar análisis de vulnerabilidades mensualmente con herramientas autorizadas.
6. Cifrar todos los datos sensibles almacenados en bases de datos locales o en la nube.
7. Realizar capacitación anual obligatoria en seguridad de la información a todos los empleados.
8. Registrar y evaluar incidentes de seguridad con un protocolo de respuesta preestablecido.

Consecuencias:

Incumplimientos serán evaluados por el Comité de Seguridad.

Posibles sanciones incluyen suspensiones, capacitaciones obligatorias adicionales y medidas disciplinarias.

Referencias:

ISO/IEC 27001:2022

GDPR

Ley 8968 – Costa Rica

Procedimiento: Trabajo Remoto**Propósito:**

Establecer un protocolo para garantizar que el trabajo remoto se realice de manera segura y eficiente, sin comprometer la información de Florabella S.A.

Alcance:

Aplica a todos los empleados autorizados para realizar trabajo remoto, ya sea parcial o permanentemente.

Responsables:

Empleados remotos

Equipo de TI

Supervisores directos

Definiciones:

VPN: Red privada virtual utilizada para asegurar la comunicación entre el usuario remoto y los sistemas de la empresa.

Endpoint: Dispositivo final que accede a la red, como laptops o teléfonos.

Instrucciones paso a paso:

1. Solicitar autorización formal al supervisor directo para trabajar remotamente.
2. Configurar el dispositivo de trabajo con antivirus, firewall y cifrado de disco.
3. Conectarse siempre mediante la VPN corporativa antes de acceder a cualquier sistema empresarial.
4. No compartir dispositivos de trabajo con terceros.
5. Reportar cualquier pérdida, robo o falla de seguridad al equipo de TI en un plazo máximo de 2 horas.
6. No almacenar archivos sensibles en el escritorio o carpetas locales del dispositivo.
7. Bloquear pantalla al alejarse del equipo y cerrar sesión al finalizar el trabajo.

8. Participar en sesiones anuales de formación sobre buenas prácticas de trabajo remoto.

Consecuencias:

Advertencias por negligencia.

Suspensión temporal del trabajo remoto si se detectan incumplimientos graves.

Sanciones según el reglamento interno en caso de filtraciones o violaciones de seguridad.

Referencias:

ISO/IEC 27001:2022

Guía NIST SP 800-46

Política de Teletrabajo MTSS – Costa Rica

Análisis de prevención de incidentes:

La implementación de estos procedimientos permite prevenir amenazas como accesos no autorizados, pérdida de datos, vulnerabilidades en sistemas y filtraciones de información.

En el caso de la seguridad de la información, el uso del cifrado, las auditorías y los respaldos frecuentes ayudan a mantener la continuidad del negocio. En el trabajo remoto, el acceso seguro, el uso de VPN y la capacitación constante reducen los riesgos asociados al trabajo fuera de la oficina, fortaleciendo la postura general de seguridad de Florabella S.A.

Reflexión Final

1. ¿Cómo las políticas de seguridad pueden proteger la información de los clientes y los procesos operativos en una floristería que depende tanto de una tienda física como de una plataforma en línea?

Las políticas de seguridad establecen controles técnicos y administrativos que garantizan la **confidencialidad, integridad y disponibilidad** de la información de los clientes y de los procesos críticos. En el caso de una floristería como Florabella S.A., que opera tanto en tienda física como en línea, estas políticas aseguran que los datos personales y de pago de los clientes estén **cifrados**, se acceda a ellos bajo el **principio de mínimo privilegio**, y se **monitoreen los accesos** en todo momento. Además, la realización de **copias de seguridad automáticas**, la segmentación de red para proteger el POS y la plataforma e-commerce, y el uso de **autenticación multifactor (MFA)** permiten mantener operativos los procesos incluso frente a incidentes de seguridad.

2. ¿Qué desafíos específicos enfrenta el trabajo remoto en términos de seguridad de la información y cómo puede abordarlos una política efectiva?

El trabajo remoto introduce riesgos como el **uso de redes Wi-Fi inseguras**, **pérdida o robo de dispositivos**, **malware en equipos personales**, y **acceso no autorizado** a sistemas empresariales. Una política efectiva aborda estos desafíos estableciendo medidas como el uso obligatorio de **VPN corporativa**, **antivirus actualizado**, **cifrado de disco**, y la prohibición de usar redes públicas sin protección. También se requieren **protocolos de notificación inmediata** en caso de incidentes, **capacitación periódica** y **auditorías de cumplimiento**. Estas acciones fortalecen la seguridad de la información aun cuando los empleados trabajan fuera del entorno controlado de la oficina.

3. ¿De qué manera las políticas de seguridad de la información deben adaptarse para cumplir con las normativas aplicables a empresas con operaciones tanto físicas como digitales?

Las políticas deben ser **integrales y coherentes**, abarcando tanto los sistemas físicos como digitales, y alinearse con normativas como **ISO/IEC 27001**, **GDPR**, y leyes locales como la **Ley 8968 de Costa Rica**. Esto implica incluir definiciones claras sobre qué constituye información confidencial o personal, establecer **controles de acceso**, asegurar el **cifrado de datos**, mantener registros de auditoría y garantizar el **consentimiento informado** para el tratamiento de datos. Además, deben contemplar **procesos de evaluación periódica**, análisis de impacto (BIA), y simulaciones de riesgo (como Monte Carlo) para justificar inversiones en seguridad y asegurar la continuidad operativa frente a amenazas.